



**HOGESCHOOL
UTRECHT**



TESTEN INFORMATIEBEVEILIGING



Naam: Ali Othman

Mei 22, 2025

Student nummer : 1860574

P2_S3_Testen informatiebeveiliging

Index

- Inleiding _____ 4-5
 - Wat is informatiebeveiliging?
 - Belang van informatiebeveiliging
 - Informatiebeveiliging & Cyber Security
- Informatiebeveiliging methodes _____ 6-13
 - Mens, Proces en Techniek
 - Wat is security maturity?
 - Het security maturity model
 - informatiebeveiligingscontroles
 - Risicomanagement
 - Stappen in Risicomanagement
 - Risicomanagementmethode: ISO/IEC 27005
 - Voorbeeld: Toepassing op een besturingssysteem (Windows)
 - Reflectie op Risicomanagement
 - Toegangsbeheer
 - Toegangsbeheer onderdelen
 - Voorbeeld: Toegangsbeheer in Windows Active Directory
 - Reflectie op Toegangsbeheer
 - Beveiligingsstandaarden & Best Practices
 - Wat zijn CIS Controls?
 - Voorbeeld van enkele CIS Controls:
 - Voorbeeld: Toepassing op een besturingssysteem (Windows)
 - Reflectie op CIS Controls

Naam: Ali Othman

Mei 22, 2025

Student nummer : 1860574

P2_S3_Testen informatiebeveiliging

- 2 Methodes voor het Testen van Informatiebeveiliging ————— 14-16
 - Penetratietest (Pentest)
 - Waarom is een penetratietest belangrijk?
 - Voorbeeld: Webapplicatie Pentest
 - Audit van Informatiebeveiliging
 - Waarom is een audit belangrijk?
 - Voorbeeld: ISO 27001 Audit
- Algemene Conclusie ————— 16
- Bronnenlijst ————— 16

Inleiding

Informatiebeveiliging is essentieel in een tijd waarin digitale gegevens voortdurend worden bedreigd. Het doel is om informatie te beschermen tegen ongeautoriseerde toegang, wijziging en verlies. Deze opdracht behandelt enkele methodes voor informatiebeveiliging en testtechnieken op verschillende besturingssystemen om inzicht te geven in hun werking en effectiviteit.

Wat is informatiebeveiliging?

Informatiebeveiliging is het beschermen van digitale en fysieke informatie tegen ongeautoriseerde toegang, gebruik, wijziging of vernietiging. Het doel is om de vertrouwelijkheid, integriteit en beschikbaarheid van gegevens te waarborgen. Goede informatiebeveiliging zorgt ervoor dat gevoelige data alleen toegankelijk is voor bevoegde personen en dat systemen betrouwbaar blijven functioneren.



Belang van informatiebeveiliging

Informatiebeveiliging is cruciaal omdat steeds meer data digitaal wordt opgeslagen en verwerkt. Zonder goede beveiliging lopen organisaties en individuen het risico op datalekken, cyberaanvallen en verlies van vertrouwelijke informatie. Dit kan leiden tot financiële schade, reputatieverlies en juridische problemen. Daarnaast zorgt een goede informatiebeveiliging ervoor dat systemen betrouwbaar blijven werken en dat bedrijfsprocessen niet worden verstoord. Het beschermen van gegevens is daarom essentieel voor het vertrouwen van klanten, medewerkers en partners.

Informatiebeveiliging & Cyber Security

Informatiebeveiliging en cybersecurity worden vaak door elkaar gebruikt, maar ze hebben elk een eigen focus. Ze overlappen deels, maar zijn niet precies hetzelfde.

Informatiebeveiliging (Information Security)

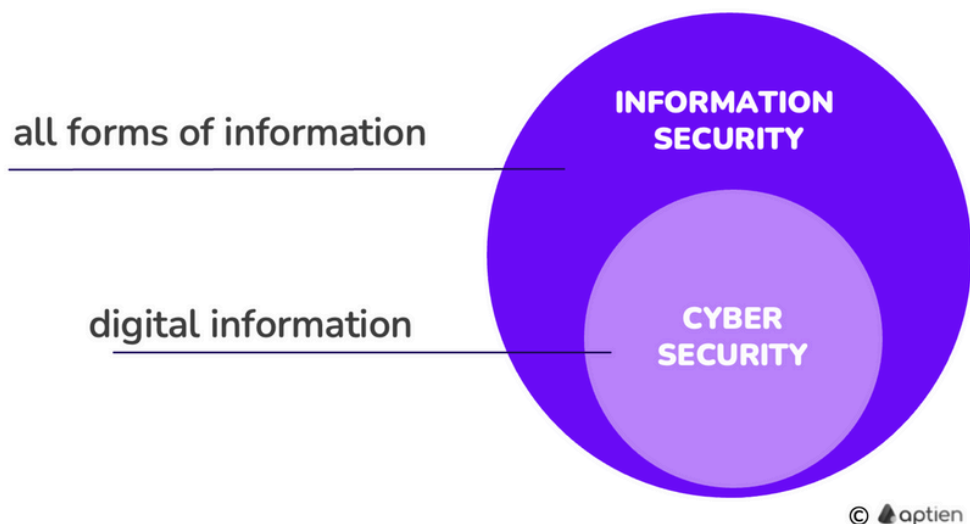
Informatiebeveiliging richt zich op het beschermen van alle vormen van informatie, ongeacht of die digitaal, op papier of mondeling is. Het doel is om de vertrouwelijkheid, integriteit en beschikbaarheid van informatie te waarborgen.

- Voorbeeld: Een afgesloten archiefkast met vertrouwelijke papieren is ook een vorm van informatiebeveiliging.

Cybersecurity

Cybersecurity is een onderdeel van informatiebeveiliging en richt zich specifiek op het beveiligen van digitale systemen, netwerken en data tegen cyberdreigingen zoals hackers, malware en phishing.

- Voorbeeld: Het installeren van antivirussoftware of het beveiligen van een netwerk met een firewall valt onder cybersecurity.



Informatiebeveiliging methodes

1. Mens, Proces en Techniek

Bij meeste bedrijven bestaat informatiebeveiliging uit drie focusgebieden: mens, proces en techniek. Deze drie focusgebieden vormen samen het niveau van jouw informatiebeveiliging. Dit niveau wordt gemeten met het security maturity model. Hoe hoger je scoort op het security maturity model, des te beter je organisatie is beveiligd.

- **Mens:** Bewustwording en training van medewerkers zijn cruciaal. Menselijke fouten vormen namelijk een groot risico. Goede instructies en gedragsregels helpen medewerkers om veilig om te gaan met informatie.
- **Proces:** Duidelijke procedures en beleidsregels zorgen ervoor dat beveiliging systematisch wordt toegepast. Dit omvat onder andere incidentmanagement, toegangsbeheer en regelmatige audits.
- **Techniek:** Technische maatregelen zoals firewalls, encryptie en antivirussoftware beschermen systemen en data tegen aanvallen van buitenaf. Ook updates en patchmanagement vallen hieronder.

Wat is security maturity?

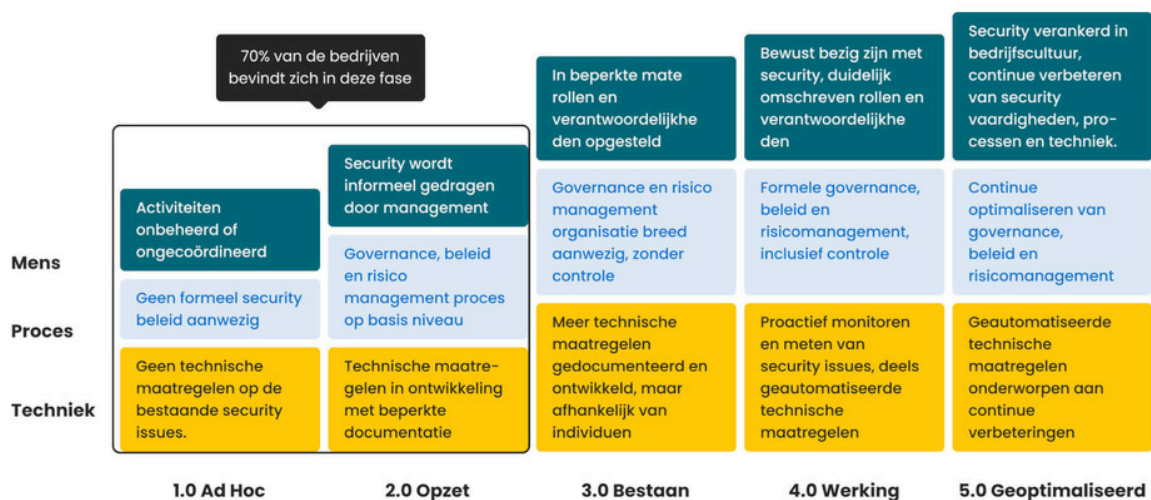
Security maturity verwijst naar het niveau van volwassenheid van de informatiebeveiliging van een organisatie. Het gaat hierin om het proces, het menselijk handelen binnen een organisatie en de weerbaarheid van de technologieën. Het doel van security maturity is om de risico's te verminderen en de operationele efficiëntie op gebied van informatiebeveiliging te verbeteren.

Het security maturity model

Het security maturity model is een raamwerk dat organisaties helpt om hun informatiebeveiliging niveau te evalueren en te verbeteren. Het model beschrijft vijf verschillende niveaus van beveiligings-volwassenheid en biedt organisaties handvatten om hun beveiligingspraktijken te verbeteren.

Er zijn verschillende varianten van het security maturity model, maar de meest bekende is het model van NIST. Dit model beschrijft vijf niveaus:

- **Initieel:** In dit niveau zijn de beveiligingspraktijken ad-hoc en reactief. Er is geen beveiligingsbeleid en de focus ligt vooral op het reageren op incidenten.
- **Herhaalbaar:** In dit niveau worden er basisbeveiligingsmaatregelen genomen en worden er procedures ontwikkeld om incidenten te voorkomen. Er is echter nog geen samenhangend beveiligingsbeleid.
- **Gedefinieerd:** In dit niveau wordt er een samenhangend beveiligingsbeleid ontwikkeld en worden er procedures en protocollen opgesteld om de beveiliging te waarborgen. Denk aan een security awareness programma.
- **Beheerst:** In dit niveau worden de beveiligingspraktijken gemonitord en geëvalueerd om te zorgen dat ze effectief zijn. Er wordt gebruik gemaakt van geavanceerde technologieën en de beveiliging wordt regelmatig getest.
- **Geoptimaliseerd:** In dit niveau wordt de beveiliging continu verbeterd en geoptimaliseerd. Er wordt gebruik gemaakt van de nieuwste technologieën en er wordt proactief gehandeld om bedreigingen te voorkomen.



informatiebeveiligingscontroles

Security controls zijn een fundamenteel onderdeel van een organisaties informatiebeveiligingsbeleid. Ze zijn niet alleen essentieel voor het beschermen van gegevens en systemen tegen cyberaanvallen, maar spelen ook een cruciale rol in het waarborgen van de naleving van wettelijke en regelgevende vereisten. Door een gedegen security control framework te implementeren, kan een organisatie aantonen dat ze verantwoordelijk en proactief omgaat met de beveiliging van haar gegevens en IT-infrastructuur.

Er zijn drie primaire categorieën van security controls:

- **Preventieve Controls:** Deze zijn ontworpen om incidenten te voorkomen voordat ze zich voordoen. Voorbeelden zijn firewall- en antivirusprogramma's, sterke wachtwoordbeleid, en encryptie van gevoelige gegevens. Deze controls helpen ongeautoriseerde toegang tot systemen en gegevens te voorkomen.
- **Detectieve Controls:** Deze controles zijn gericht op het identificeren en signaleren van beveiligingsincidenten. Intrusion Detection Systems (IDS), log monitoring, en regelmatige security audits zijn voorbeelden van detectieve controls. Ze helpen organisaties om snel te reageren op beveiligingsincidenten.
- **Responsieve Controls:** Na het detecteren van een beveiligingsincident, zijn responsieve controls essentieel om de impact te minimaliseren. Incident response plannen, disaster recovery procedures, en back-upsystemen vallen onder deze categorie. Ze zorgen voor een georganiseerde aanpak om systemen te herstellen en gegevensverlies te beperken.



**Preventieve
controls**



**Detective
controls**



**Responsieve
controls**

Naast deze categorieën zijn er ook **administratieve controls**, zoals training en bewustmakingsprogramma's, die cruciaal zijn voor het creëren van een sterke beveiligingscultuur binnen een organisatie. Deze programma's zorgen ervoor dat medewerkers zich bewust zijn van beveiligingsrisico's en begrijpen hoe ze moeten handelen in geval van een incident

Het continue beoordelen en updaten van security controls is essentieel in een steeds veranderende digitale omgeving. Organisaties moeten hun beveiligingsmaatregelen regelmatig herzien in het licht van nieuwe dreigingen, technologieën en bedrijfsprocessen. Dit omvat het bijwerken van software en systemen, het herzien van toegangsrechten en het trainen van personeel over nieuwe beveiligingspraktijken.

2. Risicomanagement

Risicomanagement is een cruciale methode binnen informatiebeveiliging. Het omvat het identificeren, beoordelen en beperken van potentiële bedreigingen voor de gegevens en systemen van een organisatie. Een sterk risicomanagementprogramma is essentieel voor een effectieve informatiebeveiligingsstrategie.

Stappen in Risicomanagement

- **Identificeren van risico's**

- In deze eerste stap wordt onderzocht welke risico's de informatie en systemen van de organisatie kunnen bedreigen zoals malware, menselijke fouten of ongeautoriseerde toegang.

- **Analyseren van risico's**

- Zodra de risico's in kaart zijn gebracht, wordt beoordeeld hoe waarschijnlijk ze zijn en wat de gevolgen kunnen zijn. Dit helpt om te begrijpen welke risico's het meest kritisch zijn.

- **Evalueren van risico's**

- De organisatie bepaalt welke risico's acceptabel zijn en welke aangepakt moeten worden. Dit gebeurt vaak met behulp van een risicomatrix of classificatiesysteem.

- **Behandelen van risico's**

- Voor elk onacceptabel risico wordt een passende beheersmaatregel gekozen. Denk aan het vermijden, verminderen, overdragen of accepteren van het risico.

- **Monitoren en evalueren**

- Risicobeheersing is een doorlopend proces. Daarom worden risico's en maatregelen regelmatig geëvalueerd. Veranderingen in de IT-omgeving of nieuwe dreigingen kunnen aanpassingen vereisen.



Risicomanagementmethode: ISO/IEC 27005

ISO/IEC 27005 is een internationale norm die speciaal gericht is op informatiebeveiligingsrisico's. Het sluit aan op ISO 27001 en biedt richtlijnen voor hoe je risico's kunt analyseren en behandelen binnen een Information Security Management System (ISMS). Deze methode is flexibel en schaalbaar voor verschillende soorten organisaties.

Voorbeeld: Toepassing op een besturingssysteem (Windows)

Bij het beheren van een Windows-server voert een organisatie een risicobeoordeling uit. Ze identificeren als risico dat onbeveiligde RDP (Remote Desktop Protocol) toegang van buitenaf mogelijk is.

Kans: Hoog, want poort 3389 is open.

Impact: Groot, omdat het systeem gevoelige klantgegevens bevat.

Maatregel: De organisatie zet RDP achter een VPN, verplicht MFA (multifactor-authenticatie) en logt alle inlogpogingen.

Reflectie op Risicomanagement

Risicomanagement helpt om beveiliging doelgericht en kostenbewust in te zetten en ondersteunt prioriteiten en audits. Nadelen zijn dat het tijdrovend kan zijn, kennis vereist en complex wordt bij grote of veranderlijke IT-omgevingen.

3.Toegangsbeheer

Toegangsbeheer is een fundamentele methode binnen informatiebeveiliging die ervoor zorgt dat alleen geautoriseerde personen toegang hebben tot systemen, netwerken, toepassingen en gegevens. Het bepaalt wie wat mag doen binnen een IT-omgeving, op basis van rollen, rechten en identiteit.

Toegangsbeheer onderdelen

- Identificatie – wie ben je?
- Authenticatie – bewijs dat jij bent wie je zegt dat je bent.
- Autorisatie – wat mag je doen of bekijken?
- Auditing – vastleggen en controleren van wie wat heeft gedaan.

Voorbeeld: Toegangsbeheer in Windows Active Directory

Windows Active Directory wordt vaak gebruikt om toegang tot bestanden, e-mail en applicaties te beheren op basis van gebruikersrollen, zoals HR, IT of administratie.

- Authenticatie: Gebruikers loggen in met een combinatie van gebruikersnaam, wachtwoord en multifactorauthenticatie (MFA) om hun identiteit te bevestigen.
- Autorisatie: Gebruikers krijgen alleen toegang tot de gegevens en systemen die passen bij hun functie. Bijvoorbeeld: HR-medewerkers hebben toegang tot personeelsgegevens, maar niet tot IT-beheertools.
- Toegangscontrole: Bestanden worden beveiligd met NTFS-permissies, waarbij alleen relevante groepen toegang krijgen tot specifieke mappen of bestanden.
- Auditing: Inlogpogingen en wijzigingen in toegangsrechten worden automatisch gelogd, zodat misbruik of fouten kunnen worden opgespoord.

Reflectie op Toegangsbeheer

Toegangsbeheer verhoogt de veiligheid en biedt controle over wie toegang heeft tot welke onderdelen. Het is flexibel in te richten via rollen en groepen. Tegelijk vraagt het om goed beheer en kan het bij fouten leiden tot te weinig of juist te veel toegangsrechten, vooral in complexe omgevingen.

4.Beveiligingsstandaarden & Best Practices

Beveiligingsstandaarden zijn internationaal erkende richtlijnen en normen die organisaties helpen om hun informatie op een systematische en veilige manier te beschermen. Ze bieden structuur, helpen risico's te beheersen en maken het makkelijker om aan wet- en regelgeving te voldoen zoals CIS Controls.

Wat zijn CIS Controls?

De Center for Internet Security Controls (CIS Controls) zijn een set van 18 concrete beveiligingsmaatregelen die ontworpen zijn om de meest voorkomende cyberaanvallen te voorkomen. Ze zijn verdeeld in drie niveaus (IG1, IG2, IG3) op basis van risico en complexiteit van de organisatie.

Voorbeeld van enkele CIS Controls:

- Inventory of Assets
 - Registratie van alle apparaten en systemen om te weten wat beschermd moet worden.
- Secure Configuration
 - Instellen van veilige standaardconfiguraties en verwijderen van onnodige functies.
- Access Control Management
 - Beperken van toegang tot alleen wat nodig is, met sterke verificatie.
- Continuous Vulnerability Management
 - Regelmatig zoeken naar en verhelpen van beveiligingslekken.
- Security Awareness & Skills Training
 - Medewerkers trainen in veilig gedrag en het herkennen van bedreigingen.
- Incident Response Management
 - Voorbereid zijn met een plan om snel en effectief te reageren op incidenten.

Voorbeeld: Toepassing op een besturingssysteem (Windows)

Een voorbeeld van het gebruik van Continuous Vulnerability Management binnen Windows is het automatisch installeren van beveiligingsupdates via Windows Update. Hierdoor worden kwetsbaarheden snel opgespoord en verholpen, wat de veiligheid van het systeem verhoogt.

THE 18 CIS CONTROLS



Reflectie op CIS Controls

De CIS Controls zijn praktisch en duidelijk, vooral geschikt voor kleinere organisaties. Door de prioritering zijn ze goed toepasbaar, ook met beperkte middelen. Daarnaast zijn de controles internationaal erkend en worden ze regelmatig bijgewerkt. Aan de andere kant zijn de CIS Controls niet altijd volledig dekkend voor complexe omgevingen. Het toepassen ervan vereist technische kennis, en ze zijn minder gericht op compliance dan op praktische beveiliging.

2 Methodes voor het Testen van Informatiebeveiliging

1. Penetratietest (Pentest)

Een penetratietest is een gecontroleerde en gesimuleerde aanval op een IT-systeem om kwetsbaarheden te ontdekken voordat kwaadwillenden dat doen. Hierbij probeert een beveiligingsspecialist via verschillende technieken binnen te dringen in netwerken, applicaties of systemen. Het doel is om zwakke plekken te vinden en deze te rapporteren, zodat de organisatie ze kan oplossen. Pentests zijn vaak gericht op specifieke onderdelen, zoals webapplicaties, netwerkbeveiliging of social engineering.

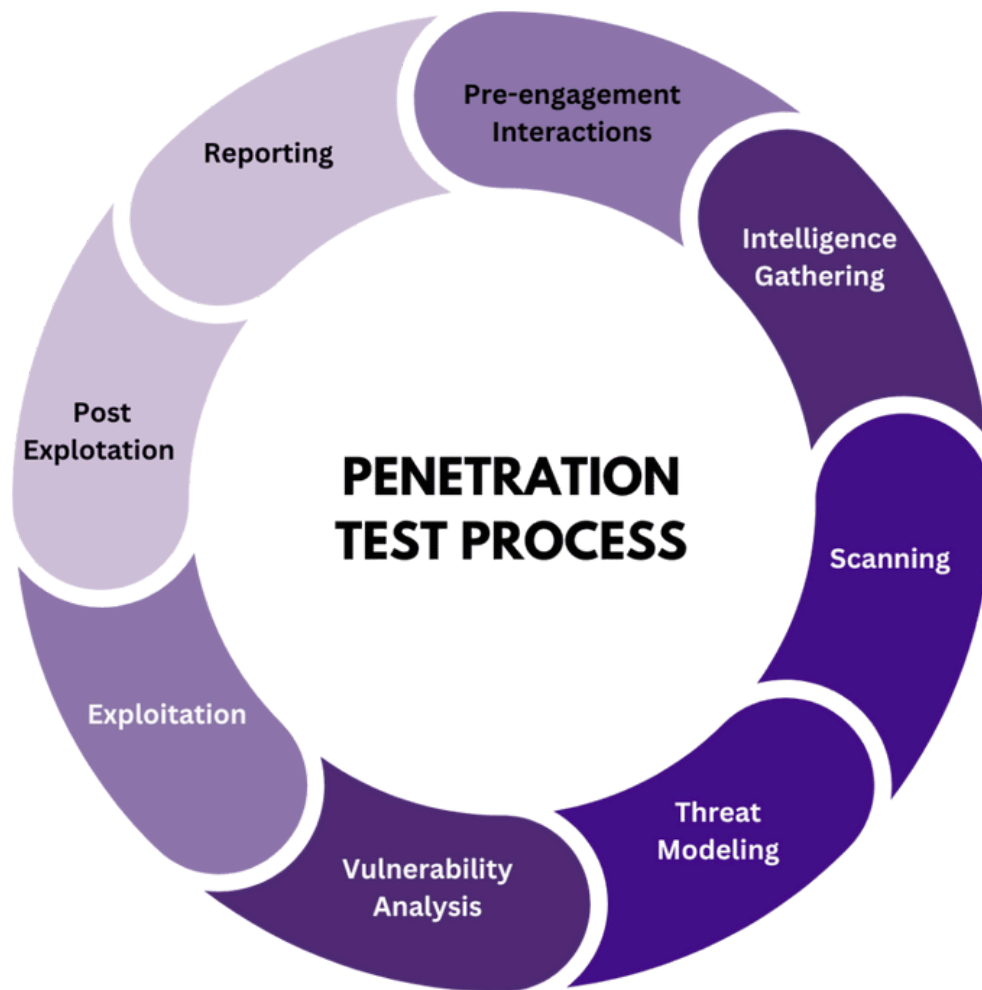
Waarom is een penetratietest belangrijk?

Een penetratietest helpt organisaties om hun digitale weerbaarheid te vergroten. Door kwetsbaarheden tijdig te ontdekken, kunnen ze gericht maatregelen nemen voordat kwaadwillenden misbruik maken van deze zwakke plekken. Het draagt bij aan:

- Verhogen van de beveiliging: Zwakke plekken worden zichtbaar en kunnen worden opgelost.
- Voorkomen van schade: Datalekken, reputatieschade en financiële verliezen kunnen worden voorkomen.
- Voldoen aan wet- en regelgeving: Veel normen (zoals ISO 27001, AVG) vereisen regelmatig testen.
- Vertrouwen opbouwen: Klanten en partners zien dat beveiliging serieus wordt genomen.

Voorbeeld: Webapplicatie Pentest

Een organisatie heeft een klantenportaal waar gebruikers kunnen inloggen om facturen te bekijken. Een ethische hacker voert een penetratietest uit op deze webapplicatie. Tijdens de test ontdekt dat het inlogformulier kwetsbaar is voor een SQL-injectie. Hierdoor kan hij toegang krijgen tot de hele klantendatabase, inclusief gevoelige informatie. Na de test ontvangt de organisatie een rapport met aanbevelingen. De ontwikkelaars lossen het probleem op door veilige query's te gebruiken en extra invoervalidatie toe te voegen. Dankzij de test is een mogelijk datalek voorkomen.



2. Audit van Informatiebeveiliging

Een audit is een systematische beoordeling van het informatiebeveiligingsbeleid, processen en maatregelen binnen een organisatie. Het doel is om te controleren of deze voldoen aan interne standaarden, wetgeving of externe normen (zoals ISO 27001 of de AVG).

Waarom is een audit belangrijk?

Een audit is belangrijk omdat het controleert of de beveiligingsmaatregelen correct zijn geïmplementeerd. Daarnaast brengt een audit zowel beleidsmatige als technische verbeterpunten aan het licht. Het helpt organisaties om certificeringen te behalen of te behouden, zoals ISO 27001. Bovendien versterkt het het vertrouwen van klanten, partners en toezichthouders in de beveiliging van de organisatie.

Voorbeeld: ISO 27001 Audit

Een organisatie die ISO 27001 wil behalen, laat een externe auditor toetsen of het informatiebeveiligingsbeleid voldoet aan de eisen van de norm. De auditor bekijkt documentatie, interviewt medewerkers en controleert logs, toegangsbeheer en risicoanalyses. Als alles op orde is, volgt certificering.

Algemene Conclusie

Informatiebeveiliging is een essentieel onderdeel van elke moderne organisatie. Door het toepassen van methodes zoals risicomanagement, toegangsbeheer, awareness & training, en beveiligingsstandaarden zoals de CIS Controls, kan een organisatie zich beter wapenen tegen digitale dreigingen. Daarnaast zijn testmethodes zoals penetratietesten en audits onmisbaar om kwetsbaarheden op te sporen en de effectiviteit van beveiligingsmaatregelen te beoordelen.

Een goede informatiebeveiliging vraagt om een combinatie van mens, proces en techniek. Bewustwording onder medewerkers, technische bescherming en voortdurende evaluatie versterken samen de weerbaarheid van de organisatie. Door structureel te investeren in beveiliging wordt niet alleen risico verminderd, maar ook vertrouwen en continuïteit gewaarborgd.

Bronnenlijst

- **wikipedia. Informatiebeveiliging**
 - <https://nl.wikipedia.org/wiki/Informatiebeveiliging>
 - https://en.wikipedia.org/wiki/Risk_management
 - <https://nl.wikipedia.org/wiki/Toegangsbeheer>
 - https://en.wikipedia.org/wiki/Penetration_test
 - https://en.wikipedia.org/wiki/Information_security_audit
- **Wat is informatiebeveiliging?**
 - <https://surelock.nl/begrippen/informatiebeveiliging-definitie/>
 - <https://surelock.nl/begrippen/security-maturity/>
- **Information security vs cybersecurity: What is the difference?**
 - <https://youtu.be/RDiD0wq2VWo?si=GS4vIODQUQy9xMS9>
- **Security Controls – Types, Categories, and Functions**
 - https://youtu.be/4i0QTTJbVGU?si=tSpDVaR-Ocn_w5t9